

تقرير تقييم وتطوير منصة المراجعة الشاملة

نحو منصة متكاملة للمراجعة الداخلية والخارجية والرقابة

IIA IPPF 2024 · COSO · ISA · ZATCA

مبني على المعمارية الفعلية للنظام — دون افتراض

1. الملخص التنفيذي

يقيم هذا التقرير منصة المراجعة الشاملة الحالية ويضع خطة تطويرها إلى منصة متكاملة تجمع المراجعة الخارجية (ISA/SOCPA/IFRS/ZATCA) مع المراجعة الداخلية وإدارة المخاطر والرقابة (IIA IPPF / COSO). ويصّحّ التقرير الافتراضات التقنية الشائعة، إذ بُني على فحص الكود الفعلي لا على تقدير مفترض للبيئة. أُنجزت بالفعل في هذه المرحلة أربع وحدات جوهرية للمراجعة الداخلية داخل المنصة الحالية دون إعادة بناء: سجل المخاطر ومصفوفتها، ومكتبة الضوابط واختبارها، والملاحظات وخطط العمل والمتابعة، وجسر المراقبة المستمرة إلى الملاحظات. يتبقى نوعٌ ثانٍ من المتطلبات (صلاحيات المستخدمين متعددة الأدوار، وسجل التدقيق غير القابل للتلاعب، وبوابة المراجع الخارجي وقائمة PBC) لا يمكن تنفيذه بواقعية داخل تطبيق الصفحة الواحدة، ويستلزم تحويل المنصة إلى نظام مخدوم بقاعدة بيانات — ويُفضّل ذلك في القسم الخامس.

2. المعمارية الفعلية للنظام (تصحيح الافتراضات)

خلاًفاً للافتراض الشائع بأن النظام مبني على إطار حديث بقاعدة بيانات مركزية، فإن الفحص الفعلي للكود يبيّن الآتي:

العنصر	الافتراض السابق	الواقع الفعلي (من الكود)
لغة/إطار العمل	Django أو Node أو Laravel	خادم Python بالمكتبة القياسية (ThreadingHTTPServer)
الواجهة	قوالب خادم/إطار JS	صفحة HTML/JS واحدة مدمجة بترميز base64
قاعدة البيانات	PostgreSQL/MySQL مركزية	مخطط SQLite معرّف لكنه غير مُستغل؛ حالة العمل في متصفح المستخدم (IndexedDB)
نقاط النهاية الحيّة	واجهات REST متعددة	ثلاث فقط: GET /health · POST /api/upload/gi · GET / · GET /
المصادقة	لا توجد	HTTP Basic اختيارية بحساب واحد مشترك + سقف رفع لمنع DoS
الأدوار/الصلاحيات	غير واضحة	لا يوجد نظام أدوار متعدد ولا سجل تدقيق على الخادم

الأثر: الوحدات القائمة على البيانات والمنطق والواجهة (مخاطر، ضوابط، ملاحظات، مراقبة) بُنيت مباشرة في التطبيق الحالي وتُحفظ في المتصفح — وهو ما تم. أما الأمن الحقيقي متعدد المستخدمين فيتطلب خلفية مخدومة (القسم الخامس).

3. تحليل الفجوات (محدّث)

يوضّح الجدول حالة كل فجوة بعد تنفيذ وحدات النوع الأول:

النوع	الحالة الآن	الأولوية	الميزة / المعيار
أول	مُنقّذة ✓	عالية	سجل المخاطر ومصفوفتها (IIA/COSO ERM)
أول	مُنقّذة ✓	عالية	مكتبة الضوابط وربطها بالمخاطر
أول	مُنقّذة ✓	عالية	اختبار فعالية الضوابط (ISA 330)
أول	مُنقّذة ✓	عالية	الملاحظات وخطط العمل والمتابعة (IIA)
أول	مُنقّذة ✓ (جسر للمحرك القائم)	متوسطة	المراقبة المستمرة → ملاحظات (ISA 240)
أول	أساسها متوفر عبر ترتيب سجل المخاطر	متوسطة	خطة مراجعة سنوية مبنية على المخاطر
ثاني	قائمة — تتطلب خلفية مخدومة	متوسطة	صلاحيات المستخدمين (RBAC) + الفصل الوظيفي
ثاني	قائمة — تتطلب خادماً وقاعدة بيانات	عالية	سجل تدقيق غير قابل للتلاعب (Audit Trail)
ثاني	قائمة — تتطلب مستخدمين متعددين	عالية	بوابة المراجع الخارجي + قائمة PBC
ثاني	قائمة — بنية تحتية	متوسطة	النسخ الاحتياطي المشفّر وإقامة البيانات (PDPL)

4. الوحدات المنقّذة حديثاً (النوع الأول)

4.1 سجل المخاطر ومصفوفة المخاطر

إضافة/تعديل/حذف المخاطر بحقول: التصنيف، المالك، الاحتمال (0-1)، الأثر (0-1)، قوة الضوابط، الاستجابة (COSO)، الحالة. احتساب الخطر الكامن (الاحتمال × الأثر) والخطر المتبقي بعد الضوابط، بألوان مصنّفة (منخفض/متوسط/مرتفع/حرج). مصفوفة حرارية 5×5 قابلة للتبديل بين الكامن والمتبقي.

استيراد مخاطر مقترحة من أرصدة الميزان الجوهرية (< أهمية الأداء) + خطر الإيراد الإلزامي (ISA 240) — مشتقة من بياناتك الفعلية دون افتراض.

4.2 مكتبة الضوابط واختبارها (COSO / ISA 330)

تعريف الضوابط (النوع، التكرار، المالك، كفاية التصميم) وربط كل ضابط بخاطر من السجل.
اختبار الفعالية التشغيلية: حجم عينة + عدد استثناءات، ويُحتسب المعدل ويُصنّف الضابط (فعّال/جزئي/غير فعّال).

4.3 الملاحظات وخطط العمل والمتابعة (IIA IPPF)

الملاحظة بعناصرها الخمسة (الحالة/المعيار/السبب/الأثر/التوصية) + الأولوية والمسؤول وتاريخ الاستحقاق ونسبة الإنجاز والحالة.
توليد الملاحظات آلياً من الضوابط غير الفعّالة ومن مؤشرات المراقبة المستمرة، ولا تُغلق إلا بعد التحقق.

4.4 التكامل والتصدير

حفظ/استرجاع/تفسير كامل مع بقية جلسة المراجعة، وتصدير CSV لكل سجل، وثلاث أوراق جديدة في حزمة الإكسل: سجل المخاطر، الضوابط، الملاحظات وخطط العمل.

5. خطة إعادة البناء التقنية (النوع الثاني)

لتمكن متطلبات الأمن وتعدد المستخدمين (RBAC، سجل تدقيق، بوابة المراجع الخارجي، PBC) يلزم تحويل المنصة من تطبيق صفحة واحدة إلى نظام مخدوم، مع الحفاظ على الواجهات والوحدات الحالية.

5.1 المعمارية المستهدفة

الطبقة	التقنية المقترحة والمبرر
الخلفية (Backend)	FastAPI (Python) — امتداد طبيعي لل خادم الحالي المكتوب بـ Python، مع دعم async وواجهات REST موثقة.
قاعدة البيانات	PostgreSQL — علائقية، تدعم المعاملات والفهارس والصلاحيات؛ ترحيلات عبر Alembic.
المصادقة والصلاحيات	جلسات/RBAC + JWT على مستوى الخادم، مع فرض الفصل الوظيفي (SoD) في طبقة الخدمة.
سجل التدقيق	جدول append-only لكل عملية (من/متى/ماذا/القيمة قبل وبعد) لا يملك المستخدم صلاحية حذفه.
الواجهة	إبقاء الواجهة الحالية كما هي مع استبدال التخزين المحلي (IndexedDB) ببدائات API تدريجياً.
الاستضافة	خادم داخل المملكة (إقامة بيانات) + HTTPS + نسخ احتياطي مشفّر خارج الخادم.

5.2 نموذج البيانات الأساسي

يُنشئ على المخطط الحالي (clients / engagements / trial_balances) ويُضاف إليه: users, roles, permissions, audit_log, risks, controls, control_tests, findings, action_plans, pbc_requests, evidence.

5.3 مراحل التنفيذ والجهد التقديري

المرحلة	المحتوى	الجهد التقديري
أولى (١-٣ أشهر)	خلفية FastAPI + PostgreSQL، هجرة نماذج المخاطر/الضوابط/الملاحظات إلى الخادم، مصادقة و RBAC أولي.	≈ ٤٠٠-٦٠٠ ساعة
ثانية (٣-٦ أشهر)	سجل تدقيق append-only، إدارة الأدلة (hash)، تقارير لجنة المراجعة، الفصل الوظيفي SoD.	≈ ٦٠٠-٨٠٠ ساعة
ثالثة (٦-١٢ شهر)	بوابة المراجع الخارجي + قائمة PBC، تكامل أعمق مع Odoo، نسخ احتياطي مشفّر وامتثال PDPL.	≈ ٨٠٠-١٢٠٠ ساعة

ملاحظة: التقديرات مبدئية وتُضبط بعد ورشة تحديد نطاق مع الفريق. يمكن إبقاء المنصة الحالية عاملة أثناء البناء التدريجي للخلفية.

6. التكامل مع Odoo

يبقى Odoo نظام ERP الأساسي، ويُستورد منه عبر مركز استيراد موحّد مع قواعد تحقق:

نظام المراجعة	مصدر Odoo	قاعدة التحقق
القيود / الأستاذ	account.move.line	المدين = الدائن؛ التواريخ ضمن الفترة
شجرة الحسابات	account.account	لا حسابات مكررة
العملاء والموردون	res.partner	رقم ضريبي صحيح وموحد
الفواتير	account.move	مرتبطة بحساب والمبلغ موجب
الأصول الثابتة	account.asset	قيمة محدثة ومطابقة للإهلاك

7. الأمن والامتثال (PDPL)

تفعيل المصادقة الاختيارية القائمة قبل أي نشر، وعدم تعريض المنصة للعموم دون حماية. في مرحلة إعادة البناء: RBAC وفصل وظيفي وسجل تدقيق append-only وتشفير كلمات المرور والبيانات الحساسة. الالتزام بنظام حماية البيانات الشخصية السعودي (PDPL): موافقة، حق الحذف/النقل، وإقامة البيانات داخل المملكة. حماية الأدلة بحفظ hash لكل ملف ومنع الحذف النهائي للأدلة المرتبطة بإجراءات مراجعة.

8. أسئلة مفتوحة قبل مرحلة إعادة البناء

عدد المستخدمين وأنواع الأدوار المطلوبة فعلاً (مدير، مراجع داخلي، مالك إدارة، مراجع خارجي...). نموذج/نماذج التقارير النهائية المطلوبة (حزمة لجنة المراجعة، خطاب الإدارة). إصدار Odoo والوحدات المفعلّة، وآلية التكامل المفصّلة (API مباشر أم تصدير ملفات). متطلبات الاستضافة وإقامة البيانات والجهة المشغّلة للنظام بعد التأسيس.